

Міністерство освіти і науки України НТУУ
«Київський політехнічний інститут ім. Ігоря Сікорського»
Навчально-науковий Фізико-технічний інститут

ЕКЗАМЕНАЦІЙНА РОБОТА

з дисципліни

“Управління інцидентами комп’ютерної безпеки”

Виконав студент групи ФБ-35

Куб’юк Дмитро

Хід виконання роботи

1. Процес керування інцидентами включає: Виявлення та звітування, Тріаж, Аналіз, Реагування. Розпишіть, будь-ласка, фазу реагування: мета, задачі, процеси, результати. Наведіть різні приклади реалізації даної фази.

Метою фази реагування є мінімізація наслідків інциденту інформаційної безпеки, припинення шкідливої діяльності, відновлення нормальної роботи систем та запобігання повторенню інциденту.

Основними завданнями фази реагування є обмеження поширення інциденту, захист критичних ресурсів, усунення джерела загрози, відновлення працездатності систем, збереження цифрових доказів для подальшого розслідування.

Процес реагування зазвичай складається з кількох етапів: Спочатку виконується стримування (containment), під час якого ізолюються скомпрометовані системи, блокуються облікові записи або мережеві з'єднання, що використовуються злоумисником. Далі здійснюється усунення загрози (eradication), яке передбачає видалення шкідливого програмного забезпечення, виправлення вразливостей та очищення систем. Після цього проводиться відновлення (recovery), що включає повернення систем до нормального режиму роботи, відновлення даних із резервних копій та посилений моніторинг для виявлення повторних атак. Завершальним етапом є підготовка підсумкового звіту (lessons learned), під час якого команда аналізує причини інциденту, оцінює ефективність виконаних дій, виявляє недоліки в процесах і засобах захисту та розробляє рекомендації щодо запобігання подібним інцидентам у майбутньому.

Упродовж усієї фази підтримується комунікація з керівництвом, користувачами, партнерами та, за потреби, регуляторними органами.

Результатом фази реагування є локалізація та ліквідація інциденту, відновлення працездатності інформаційних систем, збереження доказової бази та підготовка рекомендацій щодо запобігання подібним інцидентам у майбутньому.

Залежно від типу інциденту заходи реагування можуть суттєво відрізнятися. При зараженні програмою-вимагачем основна увага приділяється ізоляції уражених систем, видаленню шкідливого програмного забезпечення та відновленню даних. У разі мережевих атак типу DDoS здійснюється фільтрація шкідливого трафіку та застосовуються механізми захисту від перевантаження сервісів. Якщо ж відбулася компрометація облікового запису користувача, виконуються заходи з відновлення контролю над обліковим записом, зокрема зміна облікових даних, завершення активних сесій та посилення автентифікації. Незалежно від типу інциденту, метою реагування залишатиметься обмеження його впливу, усунення причин та відновлення нормальної роботи систем.

2. Які типи інцидентів інформаційної безпеки ви можете назвати? Наведіть не менше 8 прикладів інцидентів різних типів, критичності та об'єктів компрометації.

Тип інциденту	Критичність	Об'єкт компрометації	Короткий опис
Фішинг / соціальна інженерія	Середня	Облікові дані користувачів; e-mail	Обманні листи/дзвінки для викрадення паролів; часто початковий вектор.
Ransomware	Критична	Файлові сервери; робочі станції; бекапи	Шифрування даних з вимогою викупу; може зупинити бізнес-процеси.
DDoS	Середня	Публічні сервіси; веб-сайти; мережеві шлюзи	Перевантаження ресурсів трафіком; призводить до недоступності сервісів.
Витік даних / ексфільтрація	Висока	Бази даних; PII; фіндані	Несанкціоноване копіювання або публікація конфіденційної інформації.
Інсайдерська загроза	Середня / Висока	Внутрішні системи; документи; доступи	Зловмисні або необережні дії співробітника, що призводять до компрометації.
Компрометація ланцюга постачання (supply-chain)	Критична	ПЗ постачальника; оновлення; CI/CD	Зараження або підміна компонентів у сторонньому ПО/сервісі.
Вразливість веб-додатка (SQLi, XSS)	Середня / Висока	Веб-сервери; БД; сесії користувачів	Експлуатація уразливостей для доступу або модифікації даних.
Ботнет / шкідливе ПЗ на кінцевих точках	Середня / Висока	Кінцеві ПК; IoT-пристрої	Масове зараження для DDoS, майнінгу або розповсюдження шкідливого ПЗ.

3. У великій організації ефективне управління інцидентами безпеки **НАЙБІЛЬШЕ** залежатиме від

У великій організації ефективне управління інцидентами безпеки найбільше залежить від наявності чітко визначених процесів реагування, розподілу ролей та ефективної координації між усіма задіяними підрозділами. Навіть за наявності сучасних засобів моніторингу та захисту, інцидент не може бути ефективно оброблений без налагодженої взаємодії між службою інформаційної безпеки, адміністраторами, керівництвом та іншими відповідальними особами.

Важливу роль відіграють затверджені процедури реагування, плани ескалації, регулярне навчання персоналу та наявність спеціалізованої команди реагування

на інциденти (CSIRT або IR Team). Саме організаційні процеси забезпечують швидке прийняття рішень, координацію дій та мінімізацію наслідків інцидентів.

4. Які з дій слід вжити, коли торгова онлайн-компанія виявляє мережеву атаку, що досі триває?

Якщо онлайн-компанія виявляє мережеву атаку, яка все ще триває, першочерговим завданням є її локалізація та обмеження подальшого впливу на інформаційні ресурси. Для цього необхідно негайно активувати план реагування на інциденти, проаналізувати характер атаки та визначити уражені системи.

Після цього слід застосувати заходи стримування, зокрема ізолювати скомпрометовані ресурси, заблокувати шкідливий трафік, оновити правила міжмережевих екранів або скористатися засобами захисту від DDoS-атак. Одночасно необхідно збирати та зберігати журнали подій, мережеві дампи та інші цифрові докази, які можуть бути використані для подальшого розслідування.

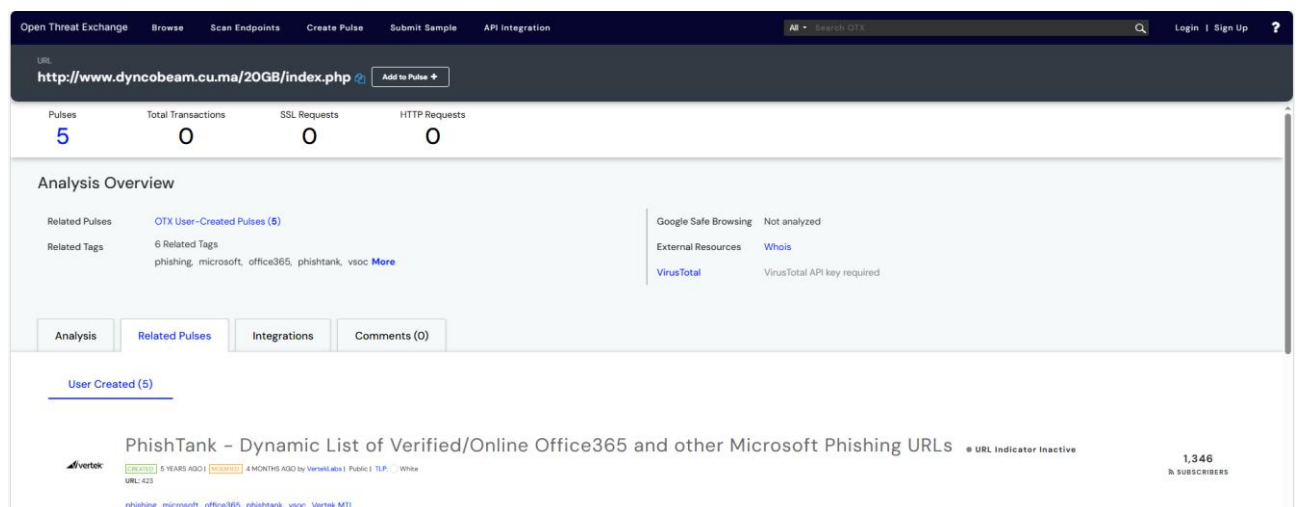
Керівництво та відповідальні підрозділи повинні бути оперативно поінформовані про ситуацію. Після локалізації атаки виконується усунення її причин, відновлення нормальної роботи сервісів та проведення післяінцидентного аналізу, під час якого визначаються недоліки захисту та заходи щодо недопущення аналогічних інцидентів у майбутньому.

5. Ваша система виявлення спрацювала на IoC:

<http://www.dyncobeam.cu.ma/20GB/index.php>. Зробіть звіт по даному індикатору, використайте в тому числі MITRE Att&ck Matrix.

- AlienVault OTX

Під час перевірки URL в AlienVault OTX було виявлено 5 пов'язаних Pulse-записів. Серед тегів, асоційованих з даним індикатором, присутні: phishing; microsoft; office365; phishtank; vsoc.

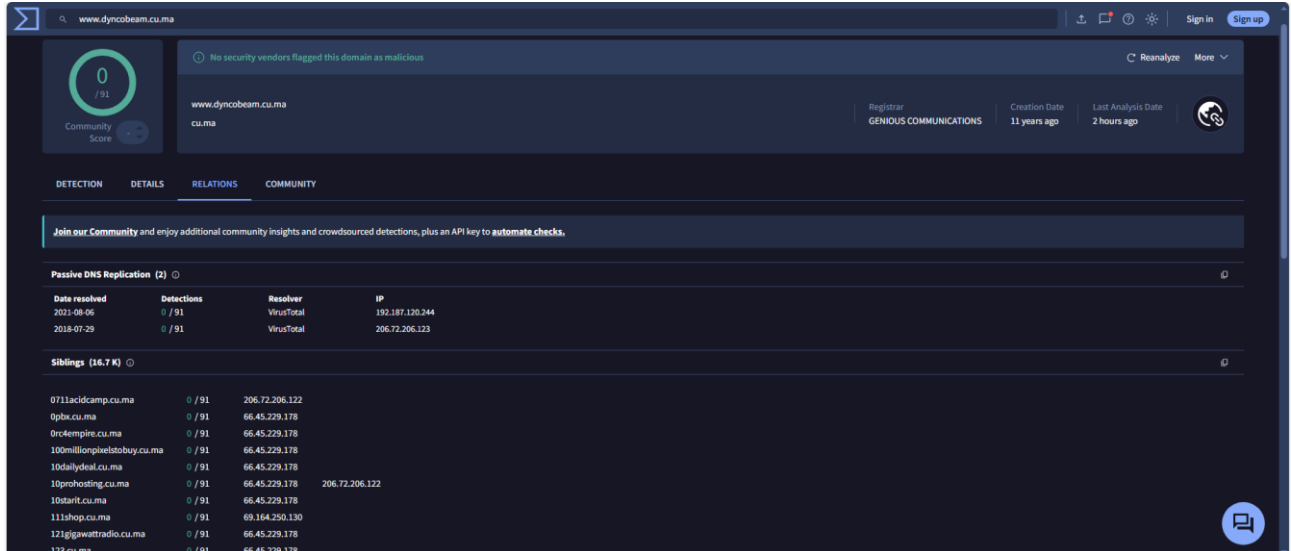


Наявність зазначених тегів, а також включення індикатора до списку “PhishTank – Dynamic List of Verified/Online Office365 and other Microsoft Phishing URLs” свідчить про його ймовірне використання у фішингових кампаніях, спрямованих на викрадення облікових даних користувачів сервісів Microsoft.

Статус індикатора в ОТХ позначений як Inactive, що означає відсутність поточної активності ресурсу на момент перевірки.

- VirusTotal

За результатами перевірки домену www.dyncobeam.cu.ma жоден із 91 антивірусного рушія не позначив ресурс як шкідливий (0/91 detections).

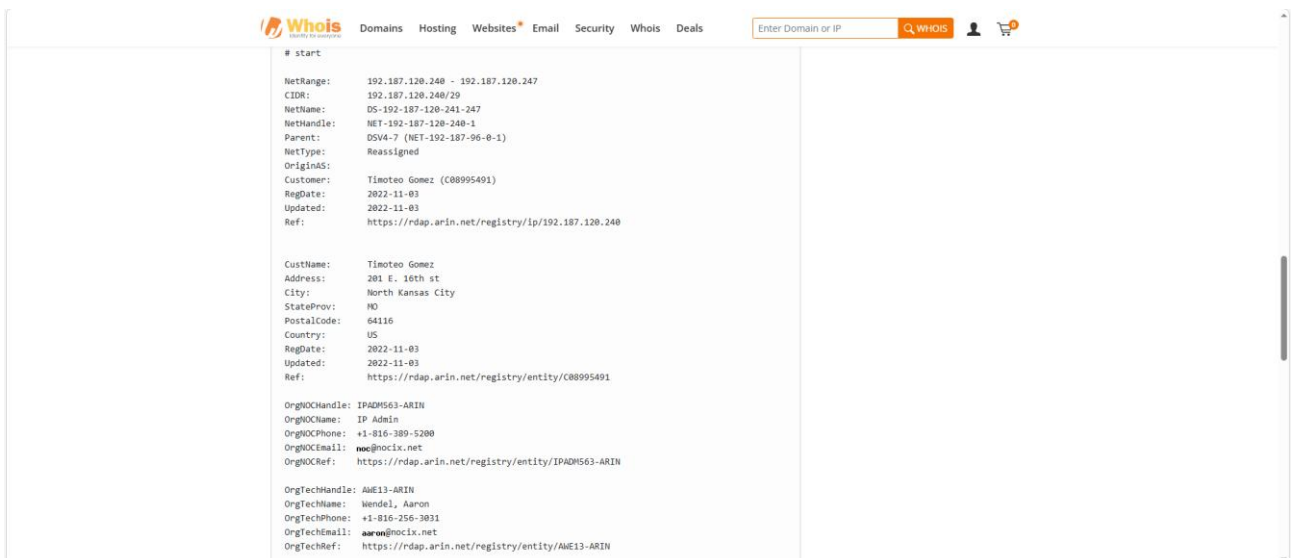


- whois

Згідно з VirusTotal, у різний час домен резолвився у такі IP-адреси:

1. 192.187.120.244

IP-адреса входить до підмережі 192.187.120.240/29, яка була виділена клієнту Timoteo Gomez (дата реєстрації – 03.11.2022) в межах автономної мережі компанії Nocix LLC (США).



Whois Domains Hosting Websites* Email Security Whois Deals Enter Domain or IP Whois	OrgTechHandle: IPADM563-ARIN OrgTechName: IP Admin OrgTechPhone: +1-816-389-5200 OrgTechEmail: noc@nocix.net OrgTechRef: https://rdap.arin.net/registry/entity/IPADM563-ARIN OrgTechHandle: KAISE102-ARIN OrgTechName: kaizer, rebecca OrgTechPhone: +1-816-256-3031 OrgTechEmail: rebecca@nocix.net OrgTechRef: https://rdap.arin.net/registry/entity/KAISE102-ARIN OrgTechHandle: REGIO-ARIN OrgTechName: Region, Bob OrgTechPhone: +1-816-256-3031 OrgTechEmail: bob@wholesaleinternet.net OrgTechRef: https://rdap.arin.net/registry/entity/REGIO-ARIN OrgTechHandle: KRH22-ARIN OrgTechName: HODLE, Kevin Robert OrgTechPhone: +1-816-506-2605 OrgTechEmail: kevin@wholesaleinternet.net OrgTechRef: https://rdap.arin.net/registry/entity/KRH22-ARIN OrgAbuseHandle: DATAS1-ARIN OrgAbuseName: DataShack Security OrgAbusePhone: +1-816-389-5200 OrgAbuseEmail: security@datashack.net OrgAbuseRef: https://rdap.arin.net/registry/entity/DATAS1-ARIN # end
---	---

2. 206.72.206.123

Аналіз IP-адреси 206.72.206.123 показав, що вона належить хостинг-провайдеру InterServer Inc. (Secaucus, New Jersey, USA). Використання комерційного хостингу є типовим як для легітимних вебресурсів, так і для інфраструктури фішингових кампаній.

Whois

Domains Hosting Websites* Email Security Whois Deals

Enter Domain or IP

Whois

NetRange: 206.72.192.0 - 206.72.207.255

CIDR: 206.72.192.0/20

NetName: INTERSERVER

NetHandle: NET-206-72-192-0-1

Parent: NET206 (NET-206-0-0-0-0)

NetType: Direct Allocation

OriginAS:

Organization: Interserver, Inc (INTER-83)

RegDate: 2011-10-03

Updated: 2012-02-24

Comment: Please use abuse@interserver.net for all abuse reports.

Ref: <https://rdap.arin.net/registry/ip/206.72.192.0>

OrgName: Interserver, Inc

OrgId: INTER-83

Address: 110 Meadowlands Pkwy

Address: 1st Floor

City: Secaucus

StateProv: NJ

PostalCode: 07094

Country: US

RegDate: 2003-03-17

Updated: 2024-11-25

Comment: Please use <https://www.interserver.net/contact-information.html> for all abuse com

Comment: DMCA registered agent dca@interserver.net

Ref: <https://rdap.arin.net/registry/entity/INTER-83>

ReferralServer: rwhois://rwhois.trouble-free.net:4321

OrgAbuseHandle: NOC1390-ARIN

OrgAbuseName: Network Operations Center

OrgAbusePhone: +1-201-605-1440

OrgAbuseEmail: abuse@interserver.net

OrgAbuseRef: <https://rdap.arin.net/registry/entity/NOC1390-ARIN>

On Sale!

iCU

.ICU @ \$1.48 ~~\$7.48~~

AI WEBSITE BUILDER

Build A Beautiful Website In Minutes!

Starts at \$2.48

Whois

Domains Hosting Websites* Email Security Whois Deals

Enter Domain or IP

Whois

OrgNOCHandle: NOC1390-ARIN

OrgNOCName: Network Operations Center

OrgNOCPhone: +1-201-605-1440

OrgNOCEmail: abuse@interserver.net

OrgNOCRef: <https://rdap.arin.net/registry/entity/NOC1390-ARIN>

OrgTechHandle: NOC1390-ARIN

OrgTechName: Network Operations Center

OrgTechPhone: +1-201-605-1440

OrgTechEmail: abuse@interserver.net

OrgTechRef: <https://rdap.arin.net/registry/entity/NOC1390-ARIN>

Додатково встановлено, що пов'язаний домен існує понад 11 років, що може свідчити про можливе повторне використання або компрометацію старої чи покинутої інфраструктури для розміщення фішингового контенту.

MITRE Att&ck Matrix

Tactic	Technique ID / Name	Description
Initial Access	T1566.002 – Phishing: Spearphishing Link	Зловмисник надсилає користувачу посилання на фішингову сторінку для викрадення облікових даних.
Credential Access	T1056 – Input Capture	Після переходу на підроблену сторінку можливе перехоплення логіна та пароля користувача.
Command and Control	T1071.001 – Application Layer Protocol: Web Protocols	HTTP/HTTPS можуть використовуватися для передачі викрадених облікових даних на сервер зловмисника.
Reconnaissance	T1593 – Search Open Websites/Domains	Зловмисник використовує зареєстровану доменну інфраструктуру для розгортання фішингових ресурсів.

У межах фази реагування рекомендується:

- Заблокувати домен dyncobeam.cu.ma на DNS-, Proxy- та Firewall-рівнях.
- Виконати пошук звернень до IOC в журналах SIEM.
- Визначити всі робочі станції, що контактували з доменом.
- Перевірити можливі компрометації облікових записів Microsoft 365.
- Скинути паролі користувачів, які відвідували ресурс.
- Увімкнути багатофакторну автентифікацію.
- Додати IOC до списків моніторингу IDS/IPS та EDR.
- Провести додаткове навчання користувачів щодо фішингових атак.

Висновок

Аналіз показав, що URL <http://www.dyncobeam.cu.ma/20GB/index.php> пов'язаний з фішинговою активністю та згадується в Threat Intelligence джерелах як ресурс, що використовувався для атак на користувачів Microsoft Office 365. Незважаючи на відсутність актуальних спрацювань антивірусних систем, наявність IOC у базах OTX та PhishTank дозволяє класифікувати його як потенційно шкідливий. Організації рекомендується заблокувати даний індикатор та провести перевірку систем, які могли взаємодіяти з ним.